

Chapter-2

Systems Vulnerability Scanning

1. Overview of vulnerability scanning.
2. Open Port/Service Identification.
3. Banner/ Version Check.
4. Traffic Probe.
5. Vulnerability Probe
6. Vulnerability Examples
7. Networks Vulnerability Scanning – Netcat
8. Understanding Port and Services tools
9. Network Reconnaissance–Nmap
10. Network Sniffers and Injection tools–Wireshark

1. Overview of vulnerability scanning

1.1 Introduction

A cybersecurity vulnerability is a weakness in software, hardware, or organizational processes that attackers can exploit to gain unauthorized access, steal data, or cause damage. These flaws stem from coding errors, misconfigurations, or human error, with AI now being used to develop new, sophisticated zero-day exploits.

Vulnerability scanning is the automated process of identifying weaknesses in computer systems, applications, and networks.

Vulnerability scanning is an automated, proactive cyber security process that uses specialized software to identify, analyze, and report security flaws, misconfigurations, and vulnerabilities within an organization's network, systems, or applications. It acts as an early detection tool to help security teams patch weaknesses before attackers exploit them to cause breaches.

1.2 It helps security professionals detect:

- Open ports
- Running services
- Weak passwords
- Outdated software
- Misconfigurations
- Security loopholes

Objectives of Vulnerability Scanning

- Detect security weaknesses
- Minimize attack surface
- Improve system security
- Ensure compliance with standards
- Reduce cyber attack risks

Types of Vulnerability Scans

1. Network Scanning

Scans network devices and identifies vulnerabilities.

2. Host Scanning

Examines individual systems.

3. Web Application Scanning

Finds vulnerabilities in websites and web apps.

4. Database Scanning

Checks database security configurations.

2. Open Port/Service Identification

2.1 Introduction

Open port service identification is the process of scanning network endpoints (TCP/UDP) to determine which are accepting connections and identifying the specific software/version listening on them. Tools like Nmap are standard, using -sV for version detection to identify services like HTTP (80) or SSH (22) for security assessments.

A port is a logical communication endpoint.

Open ports allow systems to communicate with external devices.

Examples:

Port Number	Service
21	FTP
22	SSH
23	Telnet
25	SMTP
53	DNS
80	HTTP
443	HTTPS

2.1 Importance of Open Port Identification

- Detect exposed services
- Identify unnecessary services
- Reduce attack opportunities

2.2 Risks of Open Ports

- Unauthorized access
- Malware entry points
- Service exploitation

2.3 Key Tools for Identifying Open Ports & Services

- **Nmap:** The industry-standard tool for network discovery and security auditing.
 - 1) Basic Scan: `nmap <target>`
 - 2) Service Version Detection: `nmap -sV <target>`
 - 3) Aggressive Scan (OS, Version, Scripts): `nmap -A <target>`
- **Netcat (nc):** Used for banner grabbing and manual port checking (`nc -zv <target> <port>`).
- **Masscan:** High-performance port scanner for massive networks.
- **Online Scanners:** Tools like Pentest-Tools or DNSChecker allow for quick external scans.

2.4 Methods for Service Identification

- **Banner Grabbing:** Connecting to a port and reading the application header (e.g., Apache/2.4.7).
- **Service Probing:** Sending specific packets to determine the service type based on its response (used by `nmap -sV`).
- **Packet Filtering Analysis:** Distinguishing between 'open' (accepts packets), 'closed' (no service listening), and 'filtered' (firewall blocking).

- **Security Implications**

Identifying open ports is critical for minimizing the attack surface. Unnecessary or unpatched services (e.g., outdated SSH, SMB) can act as entry points for attackers to enter networks or spread malware

3. Banner/ Version Check

3.1 Introduction

Banner grabbing is a reconnaissance technique used by security professionals to identify network services and software versions running on open ports. By connecting to a service (e.g., FTP, HTTP) and reading its welcome message, you can identify the software type and version, which helps in identifying vulnerabilities (CVEs) or system information.

Banner grabbing is used to collect information from services.

3.2 Information obtained:

- Service name
- Software version
- Operating system
- Server details

Example: Apache/2.4.49,OpenSSH_8.2

3.3 How to Check Service Banners

- Netcat: Use `nc -vv <target> <port>` to connect and view the banner.
- Telnet: Connect via `telnet <target> <port>` to view header responses, such as GET / HTTP/1.0.
- Tools: Use automated tools like ID Serve or Netcraft to analyze web server and non-HTTP services.
- Nmap: Use `nmap -sV` for intense service version detection.

3.4 Common Protocols for Banner Grabbing:

- HTTP: Reveals server type (e.g., Apache, Nginx).
- SMTP: Reveals mail server information.
- FTP: Reveals file transfer protocol server versions

3.5 Web Banner/Cookie Notice Check:

To check version and script details of cookie consent banners (e.g., OneTrust), use the Website scripts menu and select the domain to view published versions.

3.6 Web Page Banner/Image Size Check:

Right-click the banner element in your browser, select Inspect, and check the Properties or Computed tab for width and height.

3.7 Importance

Banner information helps identify:

- Vulnerable software versions
- Missing patches
- Known exploits

4. Traffic Probe

4.1 Definition

Traffic probing examines network traffic patterns.

It helps identify:

- Active hosts
- Protocols
- Response behavior

A traffic probe in cyber security is a network monitoring tool—often a sensor or appliance—that captures, analyzes, and interprets data packets moving across a network to identify security threats, performance bottlenecks, and suspicious behavior. These probes provide real-time visibility into traffic patterns, enabling detection of anomalies, malware, and data exfiltration.

4.2 Key Aspects of Traffic Probes in Cyber security:

- **Active vs. Passive Monitoring:** **Passive probes** quietly observe and copy traffic (e.g., using SPAN ports or TAPs) without interfering with flow. **Active probes** generate test traffic to measure performance, which can sometimes distort normal behavior.
- **Threat Detection & Forensics:** By continuously analyzing network behavior, probes can detect malicious activity like DDoS attacks, unauthorized access, and lateral movement. They are crucial for incident response and forensic investigations.
- **Visibility & Optimization:** Probes offer granular insights into user, device, and application activity. This helps in identifying bottlenecks, optimizing bandwidth, and ensuring compliance with security policies.
- **Traffic Types:** They analyze both **North-South** (traffic entering/leaving the network) and **East-West** (traffic moving within the network) to ensure comprehensive security coverage.

4.3 Benefits:

- **Reduced Risk:** Early detection of potential breaches prevents substantial damage.
 - **Improved Efficiency:** Probes help identify and fix performance bottlenecks.
 - **Enhanced Security Posture:** By identifying "normal" traffic, they can rapidly alert on anomalous behavior.
- If you'd like, I can:
- Explain the difference between **Network Traffic Analysis (NTA)** and **Intrusion Detection Systems (IDS)**
 - List popular **network monitoring tools** that use probes
 - Compare **packet capture** vs. **flow-based monitoring**
- Let me know if you want to **explore one of these areas!**

4.4 Information Collected

- Source IP
- Destination IP
- Protocol type
- Packet size
- Latency

4.5 Applications

- Network monitoring
- Threat detection
- Traffic analysis

5. Vulnerability Probe

5.1 Definition

Vulnerability probing actively tests systems for weaknesses.

Activities include:

- Sending test packets
- Service testing
- Patch verification

5.2 Common Checks

- Weak encryption
- Default credentials
- Open ports
- SQL injection vulnerabilities

A vulnerability probe is an active cyber security assessment technique that systematically scans systems, networks, or applications to identify security weaknesses, misconfigurations, or missing patches before malicious actors can exploit them. It involves sending traffic to a target to analyze responses, often comparing them against databases like CVE (Common Vulnerabilities and Exposures).

5.3 Key Aspects of Vulnerability Probing:

- **Active Interaction:** Unlike passive monitoring, probes actively send packets to identify open ports, service vulnerabilities, or potential flaws.
- **Automated Scanning:** Specialized software is used to quickly scan large infrastructures for known weaknesses.
- **Types of Scans:**
 - Network-based:** Scans network devices to identify open ports and weaknesses.
 - Host-based:** Analyzes individual computers for software problems and configuration issues.
 - Application-based:** Probes software code to detect flaws like injection vulnerabilities.
- **Proactive Risk Reduction:** Helps organizations prioritize remediation efforts, ensuring compliance with standards such as PCI DSS or HIPAA.

5.4 Vulnerability Probe vs. Penetration Testing:

- **Probes/Scanning:** Automated, comprehensive, and identifies potential weaknesses without attempting to gain access.
- **Penetration Testing:** Manual, in-depth simulation of an actual attack to prove a vulnerability can be exploited.

5.5 Common Tools:

- **OpenVAS:** An open-source framework for network vulnerability scanning.
- **Tenable (Nessus):** Frequently used for finding misconfigurations and vulnerabilities.

5.6 Limitations:

- Probes can sometimes cause network slowdowns or trigger false positives.
- Misconfigurations (e.g., firewall issues) can lead to failed scans that falsely report no vulnerabilities

6. Vulnerability Examples

6.1 Intro

Cyber security vulnerabilities are weaknesses in systems, software, or procedures that attackers exploit to gain unauthorized access, steal data, or disrupt operations. Common examples include unpatched software, weak authentication (passwords), misconfigured cloud services, SQL injection flaws, and human error like falling for phishing.

6.2 Top Cybersecurity Vulnerability Examples

- **Unpatched Software/Legacy Systems:** Failing to update software leaves known security holes exposed (e.g., [Log4Shell](#)).
- **Weak/Default Passwords:** Using simple, default, or unchanged passwords allows brute-force attacks.
- **SQL Injection (SQLi):** Malicious SQL code is inserted into input fields, allowing unauthorized database access.
- **Misconfigured Cloud Storage:** Publicly accessible storage buckets (e.g., AWS S3) due to improper security settings.
- **Cross-Site Scripting (XSS):** Attackers inject malicious scripts into trusted websites, targeting end-users.
- **Lack of Multi-Factor Authentication (MFA):** Relying solely on passwords makes accounts easy to hijack.
- **Insecure APIs:** Unprotected APIs act as bridges for attackers to access sensitive data.
- **Buffer Overflows:** An application writes more data to a buffer than it can hold, overwriting adjacent memory and potentially allowing code execution.
- **Phishing/Social Engineering:** Tricking users into revealing credentials or downloading malware.
- **Missing Data Encryption:** Data transmitted or stored without encryption, making it readable if intercepted.

6.3 Categorization of Vulnerabilities

Vulnerabilities often fall into three main categories:

- **Software Weaknesses:** Coding flaws, buffer overflows, insecure APIs.
- **Configuration Issues:** Misconfigured firewalls, default settings, lack of security updates.
- **Physical & Human Factors:** Unlocked doors, stolen devices, lack of security awareness.

6.4 Weak Passwords

Examples:

- admin
- 123456
- password

Risk:

- Brute force attacks

6.4 Unpatched Software

Outdated software contains known vulnerabilities.

Examples:

- Old Windows versions
- Old Apache servers

6.5 Misconfigured Firewall

Poor firewall rules expose services.

Risk:

- External attacks

6.6 Exposed Databases

Examples:

- MySQL Port 3306
- MongoDB Port 27017

Risk:

- Data leakage

7. Network Vulnerability Scanning – Netcat

7.1 Introduction

Netcat (often abbreviated as nc) is a versatile, command-line network utility known as the "Swiss Army knife" of cybersecurity and networking. It is used to read and write data across network connections using TCP or UDP protocols.

While specialized tools (like Nessus or OpenVAS) are typically used for in-depth network vulnerability scanning, Netcat is frequently used by penetration testers and system administrators for lightweight reconnaissance, port scanning, and security auditing.

7.2 Core Security Uses

- **Port Scanning:** Netcat can determine which ports are open, closed, or filtered on a target machine, identifying the active services that might harbor vulnerabilities.
- **Banner Grabbing:** By connecting to an open port, Netcat can capture the "banner" or response of a running service. This reveals the software version (e.g., an outdated, vulnerable Apache server), which is a crucial step in vulnerability identification.
- **Service Probing:** Administrators use it to manually test if specific services are responding as expected.

7.3 Basic Syntax & Usage

Netcat is executed directly from the terminal. A basic port scanning command usually looks like this:

`nc -zv <Target_IP> <Port_Range>`

-z: Tells Netcat to scan for open ports without sending any actual payload data.

-v: Enables "verbose" mode so the terminal displays the results of the scan.

w <seconds>: Sets a connection timeout so the scan moves quickly.

7.4 Other Netcat Capabilities

Beyond scanning, Netcat's raw networking power makes it a favorite tool for both legitimate IT management and malicious exploitation:

- **File Transfers:** It can be used to send and receive files between two remote machines.
- **Reverse Shells:** Security testers use it to catch or establish remote command-line access (shells) during penetration tests.
- **Backdoors & Listeners:** It can be set up to listen on a specific port, allowing a machine to act as a temporary server or chat interface.

7.5

Netcat: Netcat is a command-line networking utility.

Also called: TCP/IP Swiss Army Knife

7.5.1 Features

- Port scanning
- Banner grabbing
- File transfer
- Chat connections
- Remote connections

7.5.2 Syntax

`nc <target-ip> <port>`

Example:

`nc 192.168.1.1 80`

7.5.3 Advantages

- Lightweight
- Fast
- Easy to use

8. Understanding Port and Service Tools

8.1 Port and Service Tools

Port and Service Tools are fundamental networking and cybersecurity utilities used to map, monitor, and secure digital infrastructure. They identify active devices on a network, determine which applications are listening for connections, and verify that firewalls or routing configurations are working correctly.

Network ports act as virtual communication endpoints on a device that allow different software programs to exchange data. A port and service tool scans systems to identify open ports and the active services communicating through them. Understanding these is essential for system administration, network troubleshooting, and cybersecurity.

8.2 How Ports and Services Work

- **Logical Gateways:** Every networked device has an IP address. Ports act as virtual "doors" that direct incoming data to the correct application (e.g., an email app or a web browser).
- **Port Numbers:** Ports range from 0 to 65535. They are divided into three categories:
 - **Well-Known Ports (0 - 1023):** Reserved for core system and network protocols.
 - **Registered Ports (1024 - 49151):** Used by specific applications and vendor services.
 - **Dynamic/Private Ports (49152 - 65535):** Temporarily assigned for short-term communication

8.3 Standard Network Services

Every active service listens on a specific port. Common examples include

- **Port 22:** Secure Shell (SSH) for secure remote device access and command execution.
- **Port 80:** Hypertext Transfer Protocol (HTTP) for standard web traffic.
- **Port 443:** HTTP Secure (HTTPS) for securely transmitting sensitive data over the web.
- **Port 53:** Domain Name System (DNS) for translating web names into IP addresses.

8.4 Why Port and Service Tools are Used

Port and service tools are critical for several operational and security tasks:

- **Vulnerability Management:** Security teams use scanning tools to find unnecessary open ports or outdated services that cybercriminals could exploit.
- **Network Auditing:** Administrators use them to map an organization's network, verify which devices are running specific applications, and confirm firewall rules are working properly.
- **Troubleshooting:** They help diagnose connectivity issues by revealing if a necessary service (like a database or web server) is properly listening on its designated port.

8.5 Common Port and Service Tools

- **Nmap (Network Mapper):** The industry standard tool for network discovery and security auditing. It sends specially crafted packets to target hosts and analyzes the responses to determine which ports are open, closed, or filtered.
- **Wireshark:** A comprehensive network protocol analyzer that allows users to see network traffic in real-time. It is highly useful for examining the specific payloads and ports used in packet transfers.

- **Netcat (nc):** Often referred to as the "Swiss Army knife" of networking, this command-line utility reads and writes data across network connections using TCP or UDP, making it ideal for port scanning and testing network services.
- **Masscan:** An extremely fast port scanner that can scan the entire Internet in a few minutes, designed for large-scale network environments.

Common tools:

- Netstat
- Telnet
- Netcat
- Nmap

These tools help:

- Identify services
- Detect listening ports
- Troubleshoot networks

9. Network Reconnaissance–Nmap

9.1 Nmap (Network Mapper) is the industry standard open-source tool for network discovery and security auditing. It acts as the "digital flashlight" of cyber security, allowing both ethical hackers and system administrators to map out a target environment, identify active hosts, uncover open ports, and detect running services or operating systems.

9.2 Core Reconnaissance Capabilities

Nmap excels at the active phase of reconnaissance, performing several critical functions.

- **Host Discovery:** Determines if a target IP address or range of IPs is active and responsive.
- **Port Scanning:** Scans for open ports (status can be *open*, *closed*, or *filtered*) to see what entry points are available on a device.
- **Service & Version Detection:** Probes open ports to identify the exact application and version number listening on them.
- **OS Fingerprinting:** Analyzes the subtle nuances in a device's network responses to guess its operating system.

9.3 Key Nmap Commands & Switches

Security professionals tailor their network reconnaissance using specific flags:

- `nmap <target_ip>`: Scans the top 1000 most common ports on the target.
- `nmap -p- <target_ip>`: Scans all 65,535 TCP and UDP ports for thoroughness.
- `nmap -sV <target_ip>`: Detects the service names and version numbers running on open ports.
- `nmap -sS <target_ip>`: Performs a TCP SYN ("stealth") scan, which is fast and less likely to be logged in application logs.
- `sudo nmap -O <target_ip>`: Enables operating system detection (requires administrative privileges).

9.4 Advanced Features: Nmap Scripting Engine (NSE)

Beyond basic mapping, Nmap utilizes the Nmap Scripting Engine (NSE), which allows users to write or use pre-built scripts written in the Lua language. These scripts can be used to automatically detect known vulnerabilities, automate service discovery, and bypass certain security configurations

10. Network Sniffers and Injection tools–Wireshark

Wireshark is the world's leading open-source network protocol analyzer. It acts as a passive packet sniffer, capturing data moving across a network in real-time. While Wireshark *analyzes* traffic, specialized injection tools are required to inject packets into the network.

10.1 What is Wireshark?

Wireshark captures raw traffic from Ethernet, Bluetooth, and wireless connections, breaking it down into readable, layer-by-layer formats. It is primarily used for network troubleshooting, analyzing security vulnerabilities, and debugging protocol implementations.

- **Key Features:** Features robust display and capture filters, deep inspection of hundreds of protocols, and offline analysis capabilities.
- **Download:** Available for all major platforms on the [Official Wireshark Website](#)

10.2 Network Sniffing Mechanics

To capture traffic, a network interface card (NIC) must be put into **promiscuous mode**, allowing the device to see all packets on the local network segment rather than just those directed at it.

- **How it works:** Raw frames are logged, allowing you to observe packet contents, source and destination IPs, and payloads.
- **Ethical Usage:** Primarily used for legitimate network administration and authorized penetration testing. Unapproved packet sniffing can pose serious privacy and security risks.

10.3 Packet Injection

Unlike sniffers, which only read data, packet injection tools craft and push new packets into a network. This is often used for stress testing, simulating traffic, or testing firewall configurations.

- **Compatibility:** Wireshark is designed strictly for analysis and does not natively inject packets.
- **Companion Tools:** To inject packets, security professionals typically use command-line injection and crafting utilities like [Nemesis](#), Scapy, or tcpreplay alongside Wireshark trace

10.4 Wireshark is a network packet analyzer. Used for:

- Packet capture
- Traffic analysis
- Troubleshooting
- Security investigation

10.5 Features

- Live packet capture
- Protocol analysis
- Packet filtering
- Deep inspection

10.6 Supported Protocols

- TCP
- UDP

- HTTP
- DNS
- FTP
- SMTP

10.7 Packet Information

Each packet shows:

- Source IP
- Destination IP
- Protocol
- Length
- Payload

10.8 Advantages

- Free and open source
- GUI based
- Powerful filtering

10.9 Limitations

- Large capture files
- Requires technical knowledge

10.10 Difference Between Nmap and Wireshark

Feature	Nmap	Wireshark
Purpose	Network scanning	Packet analysis
Type	Active tool	Passive tool
Use	Discover hosts/services	Analyze traffic

Parul[®] University | **NAAC** **A++**
Vadodara, Gujarat | **GRADE**



<https://paruluniversity.ac.in/>